```
    app: agent-runtime
  policyTypes: ["Egress"]
  egress:
    - to:
        - namespaceSelector:
            matchLabels:
              name: platform
      ports:
        - port: 4000
          protocol: TCP
```

Twenty lines. It will not stop an attacker who already has execution and time, but it stops the common case.

Then there is data handling, which people forget. Prompts and responses are among the most sensitive material your company holds, and by default all of it goes into trace storage in plaintext, indefinitely. Redact at the collector, before storage. Presidio is the standard open source answer and drops into an OTel processor. Set retention on the observability store. Keeping traces forever is defensible engineering and indefensible privacy, and under the DPDP Act that distinction is legal rather than philosophical. If a customer asks where their prompts go and for how long, someone should be able to answer in a paragraph.

Supply chain is the same discipline you already apply elsewhere. Models are dependencies you did not write. Pin by digest, not a floating tag. Generate an SBOM with Syft, scan with Trivy or Grype, sign with Cosign so admission control can verify what runs. Use Safetensors instead of pickle, since pickle deserialisation executes arbitrary code. Mirror weights into your own registry, because depending on an external service staying up and a repository staying public is a risk somebody should have signed off.

Use less money

The Pune bill was a shock because nothing reported anything for thirty days. Shortening that loop is most of the work.

Tag every gateway request with team, service, and environment. Record input tokens, output tokens, cached tokens and computed cost. Send it to Prometheus and Langfuse; then put it on a Grafana board so that engineers see without looking for it. If you self-host, OpenCost or Kubecost gives GPU node cost per namespace. Together, these let you talk in unit terms: cost per conversation, per resolved ticket, per document. Those numbers survive a board meeting. Raw monthly spend only causes panic.

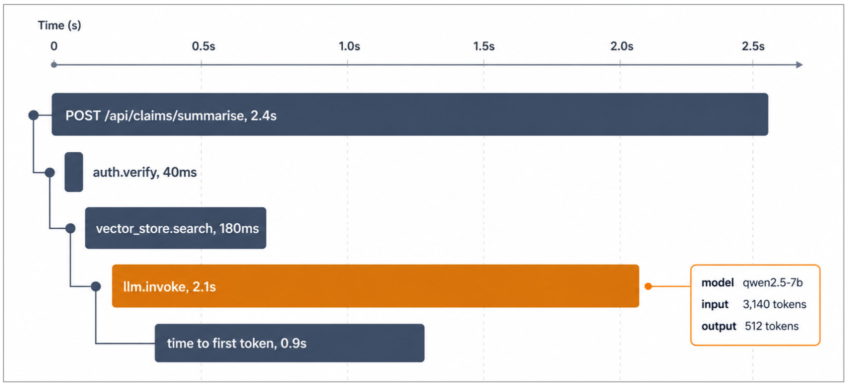

Figure 2: An LLM call as a span, nested inside the request it belongs to

Set budgets with alerts at 70 percent rather than 100 percent, with hard caps on non-production.

What brings the number down, in order of impact:

Route by difficulty: Most requests do not need your best model. Classification, extraction, routing and reformatting run well on a 7B or 8B open model you host yourself at fixed cost, leaving the expensive tier for hard reasoning. A decent router routinely halves the bill.

Cache: Exact-match caching at the gateway is free money on repeated queries. Semantic caching goes further but needs a carefully chosen threshold, since a loose one serves confident answers to questions nobody asked.

Fix your context: I audited a RAG pipeline last year that pulled twenty chunks where five sufficed and resent the full conversation history every turn. Trimming cut tokens by around 60 percent with no measurable quality drop. I check this first on every engagement now.

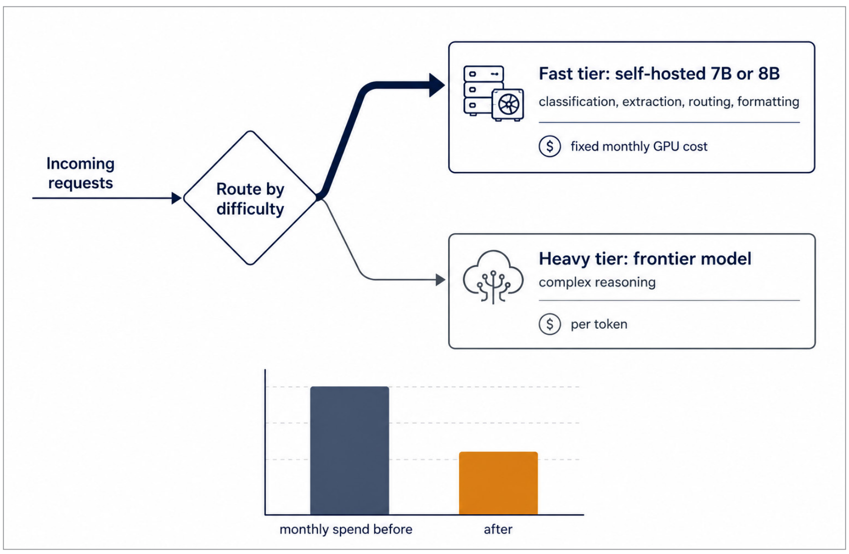

Figure 3: Most requests never need the expensive tier